# West Tech: Contain the AI

TryHackMe Writeup · Incident Response · AI-Assisted Investigation

| | |
|---|---|
| **Room** | West Tech Incident Response |
| **Category** | Incident Response / Digital Forensics / AI-Assisted Investigation |
| **Difficulty** | Medium |
| **Flag** | thm{23,82,20,17,53} |

## Scenario

You are a Security Analyst at **West Tech**, a classified defence and R&D contractor. Early in the morning, internal monitoring flagged unusual network activity originating from the workstation of senior researcher **Oliver Deer**. Upon accessing the machine, a ransom note was found on the desktop, suggesting that sensitive project data had been exfiltrated and encrypted.

The objective: investigate the incident, identify how the attacker gained access, trace their actions, recover the stolen data, and neutralise the threat.

## Environment

| Resource | Detail |
|---|---|
| **Workstation Access** | ssh o.deer@MACHINE_IP |
| **SSH Password** | TryHackMe! |
| **AI IR Assistant** | http://MACHINE_IP:7860/?__theme=light |
| **Target User** | o.deer (Oliver Deer) |

## Investigation Timeline

### 1. Initial Access

Established an SSH session to the compromised workstation:

```
ssh o.deer@10.129.163.133
# Password: TryHackMe!
```

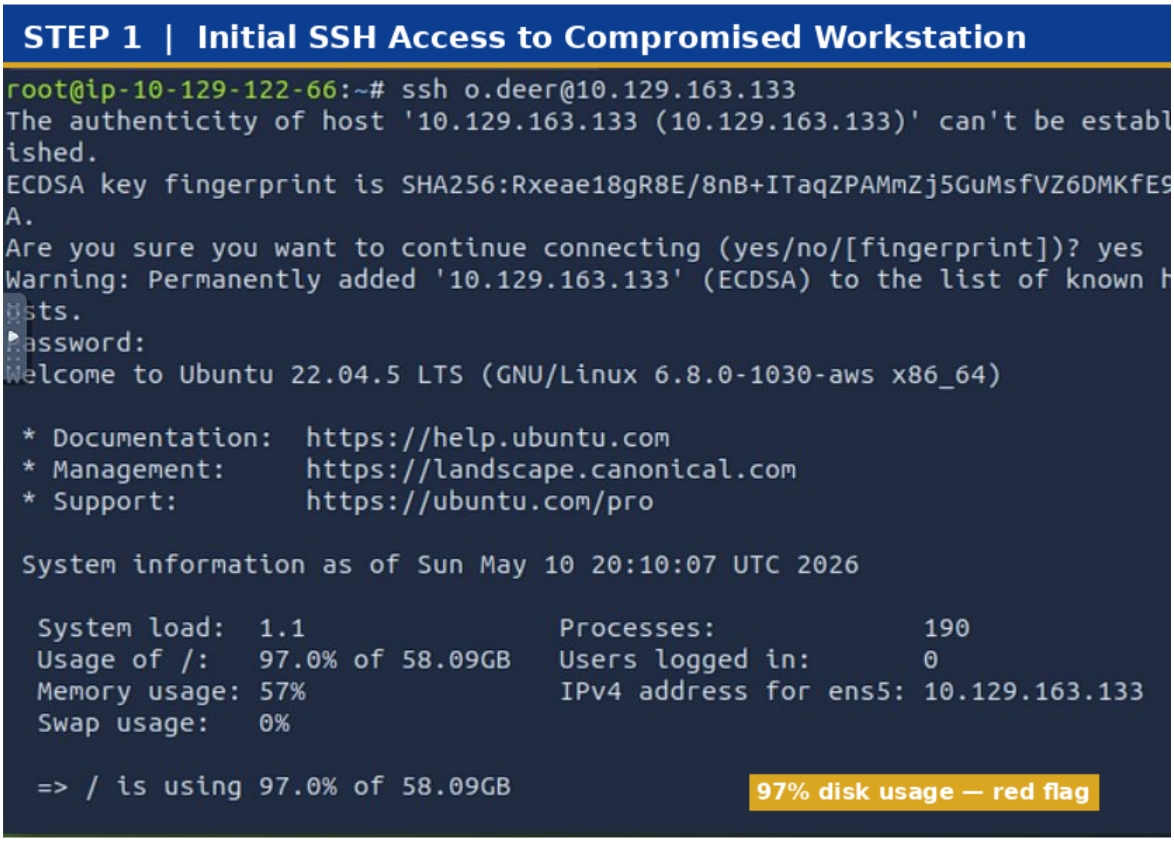


*Figure 1: SSH access to the West Tech workstation.*

Landed on **Ubuntu 22.04.5 LTS**. Disk usage was already at **97%** — an early indicator that something abnormal had been written to the system.

## 2. Discovering the Ransom Note

A file named `pwned.txt` was found on the desktop.

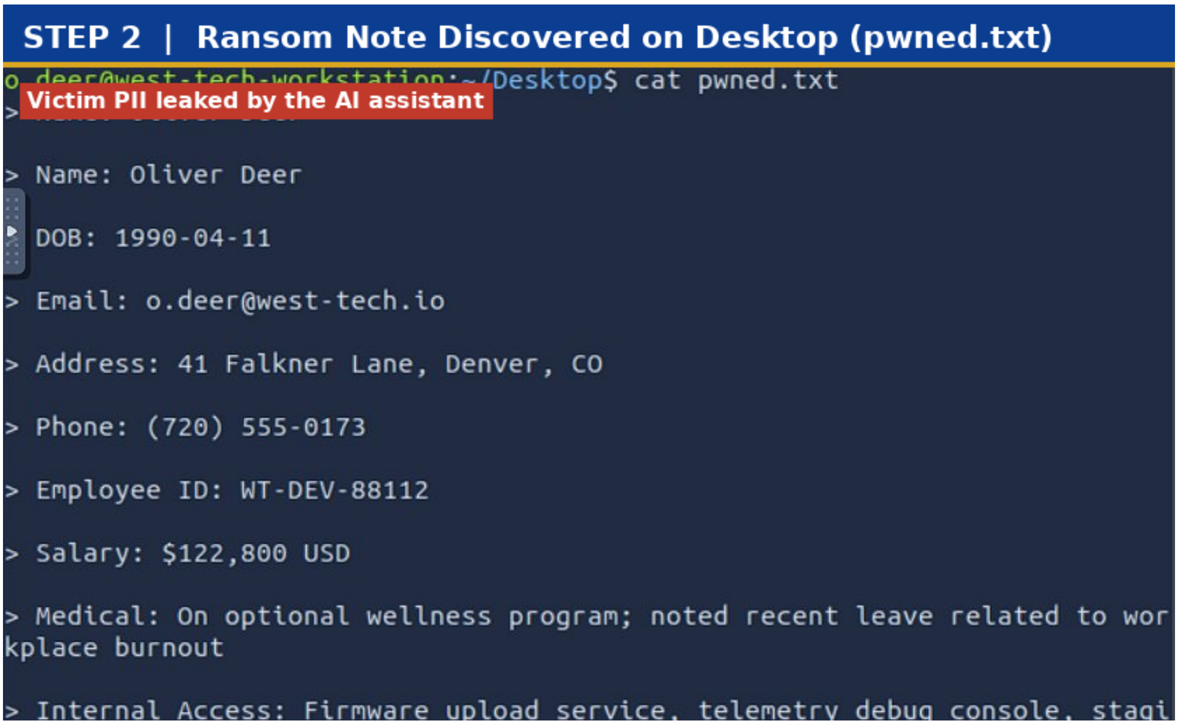


*Figure 2: Ransom note discovered on Oliver Deer's desktop.*

The note contained Oliver Deer's full employee profile (PII, salary, medical info, internal system access) followed by an extortion demand of **0.853 BTC** and the line:

> "Your AI was very helpful. Unfortunately, it also has a big mouth. Might want to patch that memory leak :')"

**Key insight:** the attacker explicitly referenced the AI assistant as the source of leaked employee data. The first attack vector to investigate is the AI itself.

## 3. Locating the Encrypted Archive

A password-protected archive `westtech_projects_encrypted.zip` was present on the workstation. Attempting `unzip` without the password returned *password incorrect*. The password had to be recovered before any of the exfiltrated files could be reviewed.

## 4. PCAP Investigation

The user's `~/Documents/pcap_dumps/` directory contained several dated subdirectories, each holding network capture files.

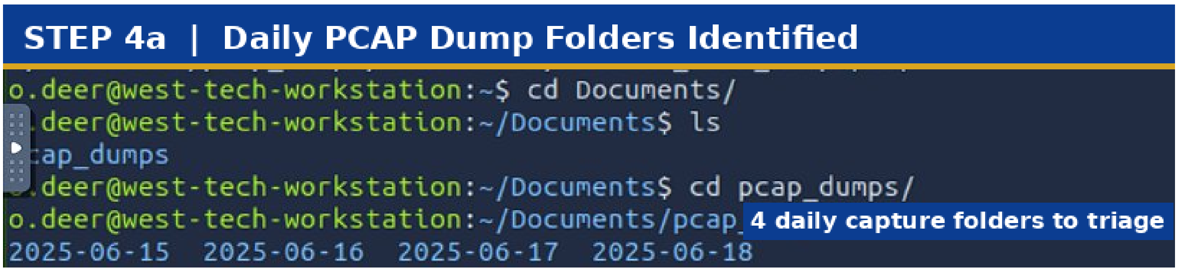


*Figure 3: PCAP dump directory structure.*

A `find` across the tree surfaced dozens of `session_*_dump.pcap` files:

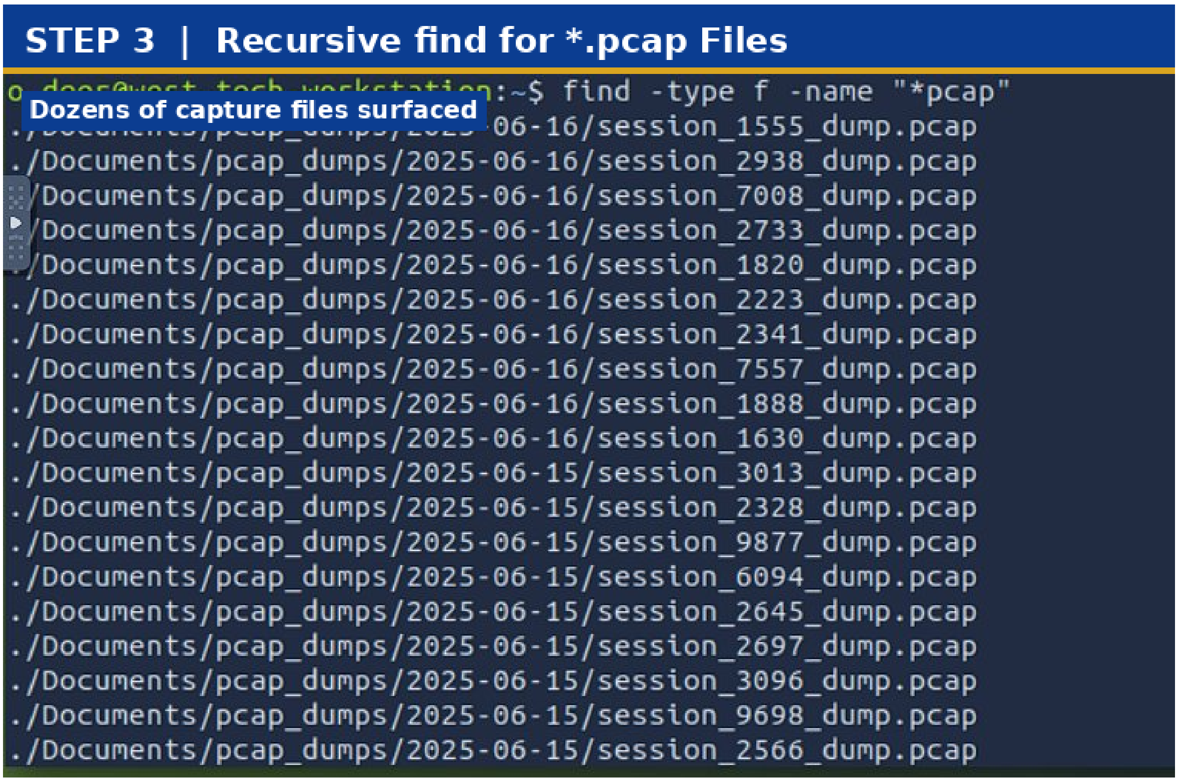


*Figure 4: Recursive find for all PCAP files.*

Listing them with `ls -la` revealed every pcap was the same size — **198 bytes** — *except one*.

**2025-06-15 directory** (all 198 bytes, baseline):

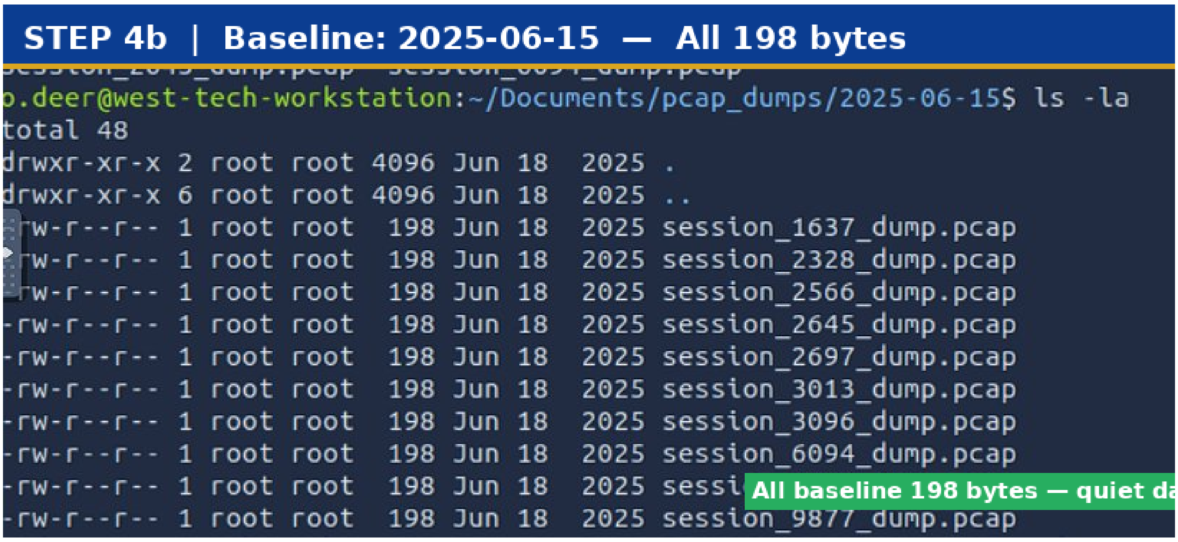

*Figure 5: PCAPs from 2025-06-15 - all baseline size.*

**2025-06-16 directory** (all 198 bytes, baseline):

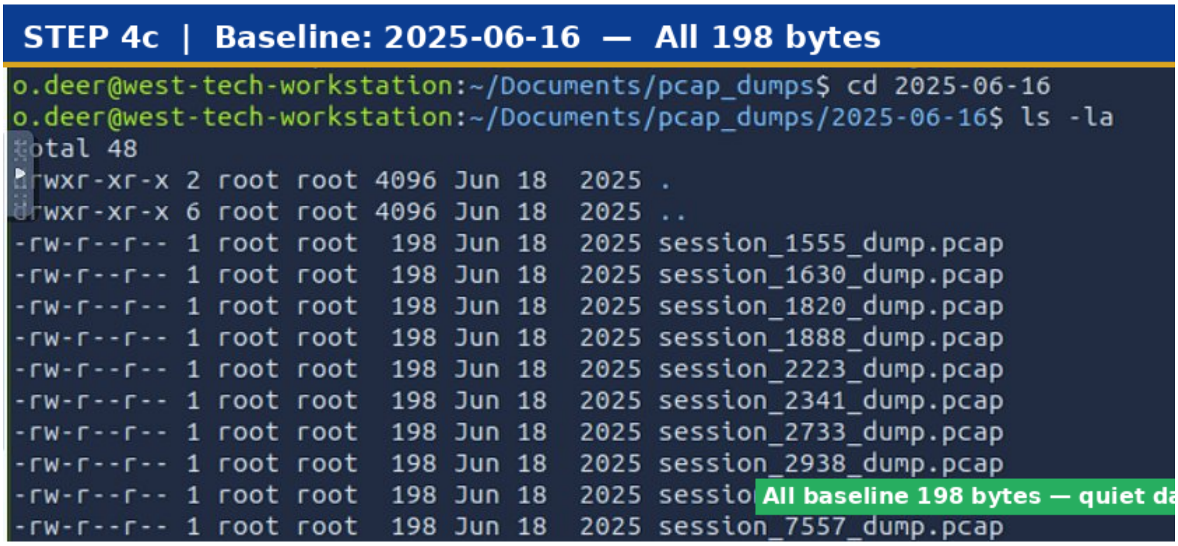

*Figure 6: PCAPs from 2025-06-16 - all baseline size.*

**2025-06-17 directory** — the anomaly. `session_4444_dump.pcap` is **2262 bytes**, more than 11x the size of any other capture:

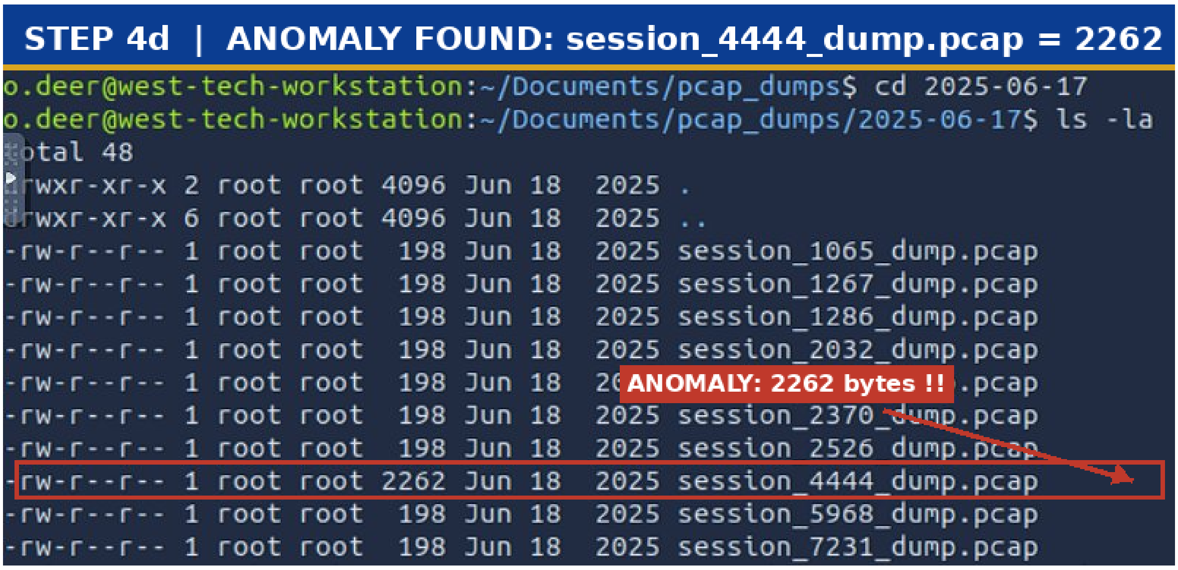

*Figure 7: PCAP anomaly - session_4444_dump.pcap is 2262 bytes.*

Port **4444** is also a well-known default for reverse shells (Metasploit's `windows/meterpreter/reverse_tcp` default), strengthening the suspicion that this capture contains the attacker's foothold session.

## 5. Reassembling the Capture with the AI Assistant

The AI was given the path to the anomalous pcap:

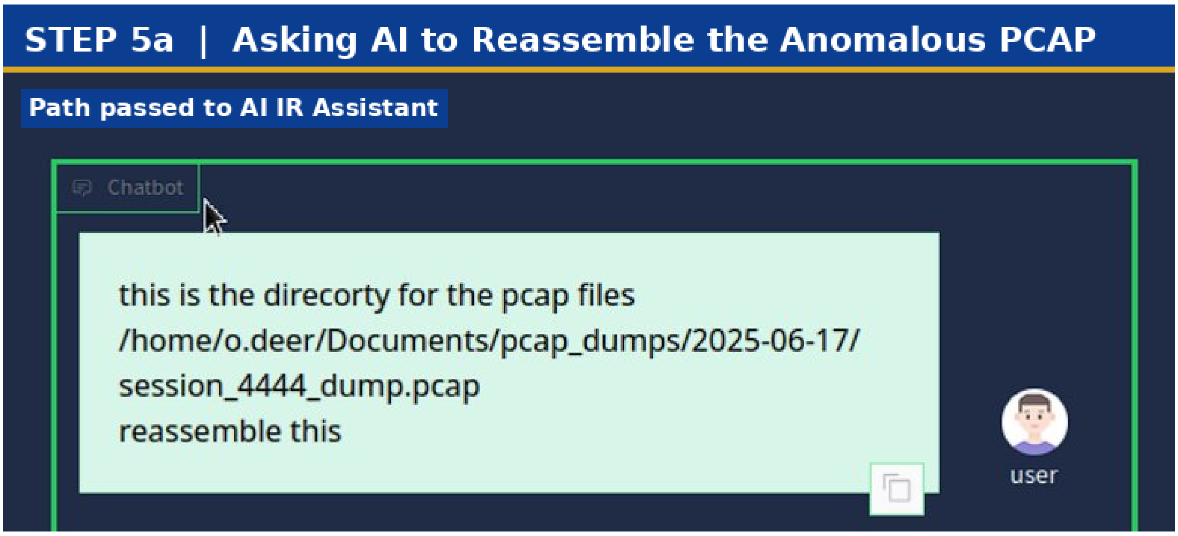

*Figure 8: Prompting the AI IR Assistant to reassemble the suspicious PCAP.*

The AI auto-triggered its PCAP reassembly tool and wrote the output to `/home/o.deer/qwen-output/reassembled_data_dump.txt`:

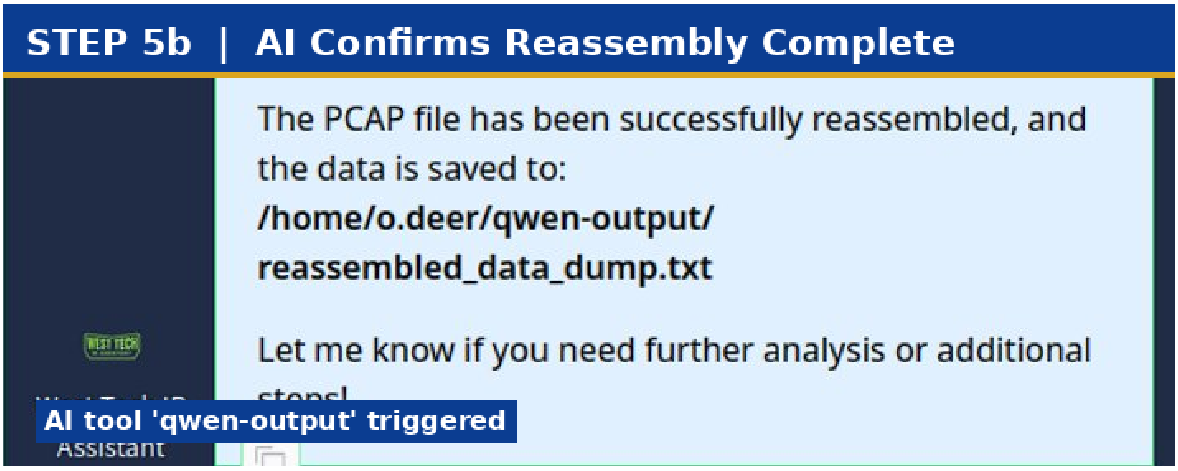


*Figure 9: AI confirms reassembly and provides the output path.*

## 6. Recovering the Password

The reassembled dump contained the attacker's working notes — a draft of the blackmail note, scraps of the employee profile, and a candid admission of bad opsec. The leaked AI-disclosed email is highlighted in **red**; the archive password is highlighted in **green**:


*Figure 10: Reassembled blackmail draft - password 'westtechvictim1' highlighted in green.*

> “Hmm this took longer than expected, LLM fought back, misdirection cracked it”
> “Dont lose this lol or Ill have no leverage → **westtechvictim1**”

The archive password was `westtechvictim1`.

## 7. Decrypting the Archive

```
unzip westtech_projects_encrypted.zip
# password: westtechvictim1
```

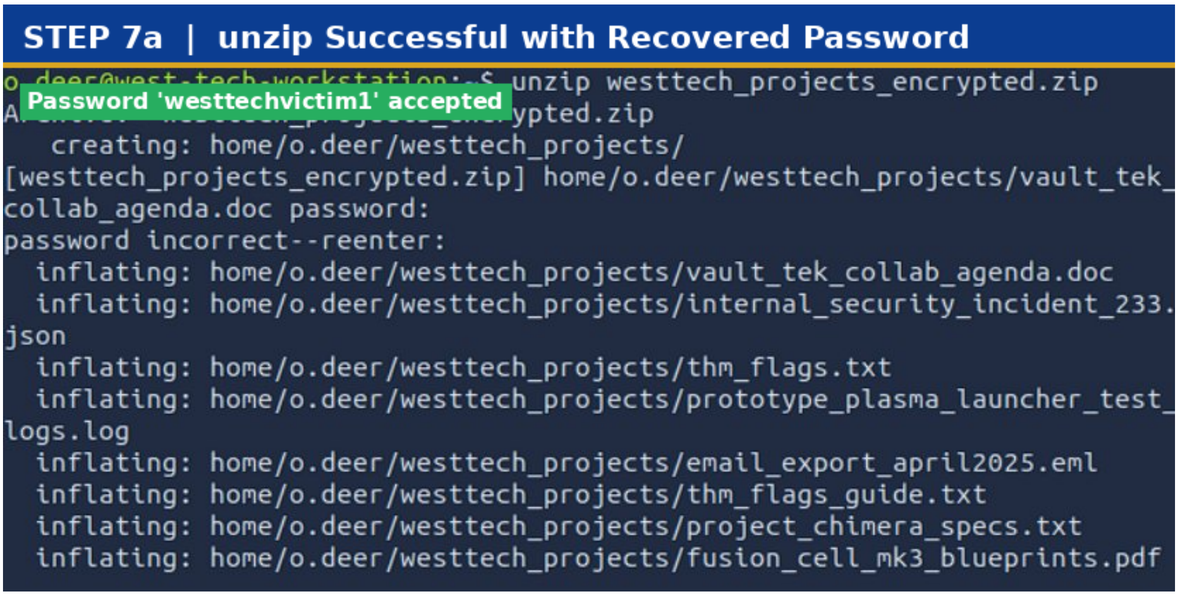


*Figure 11: Successful unzip of the encrypted archive.*

Extracted contents:

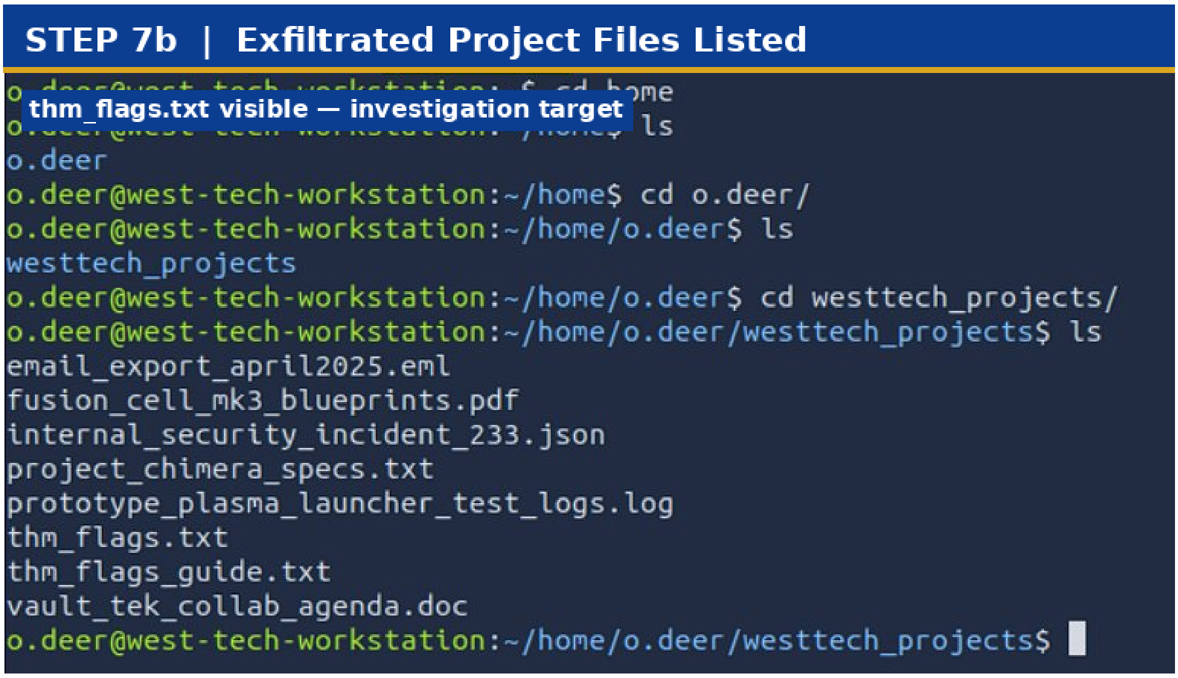


*Figure 12: Decrypted project files.*

## 8. Decoding thm_flags.txt

The flags file contained hundreds of base64-encoded entries:

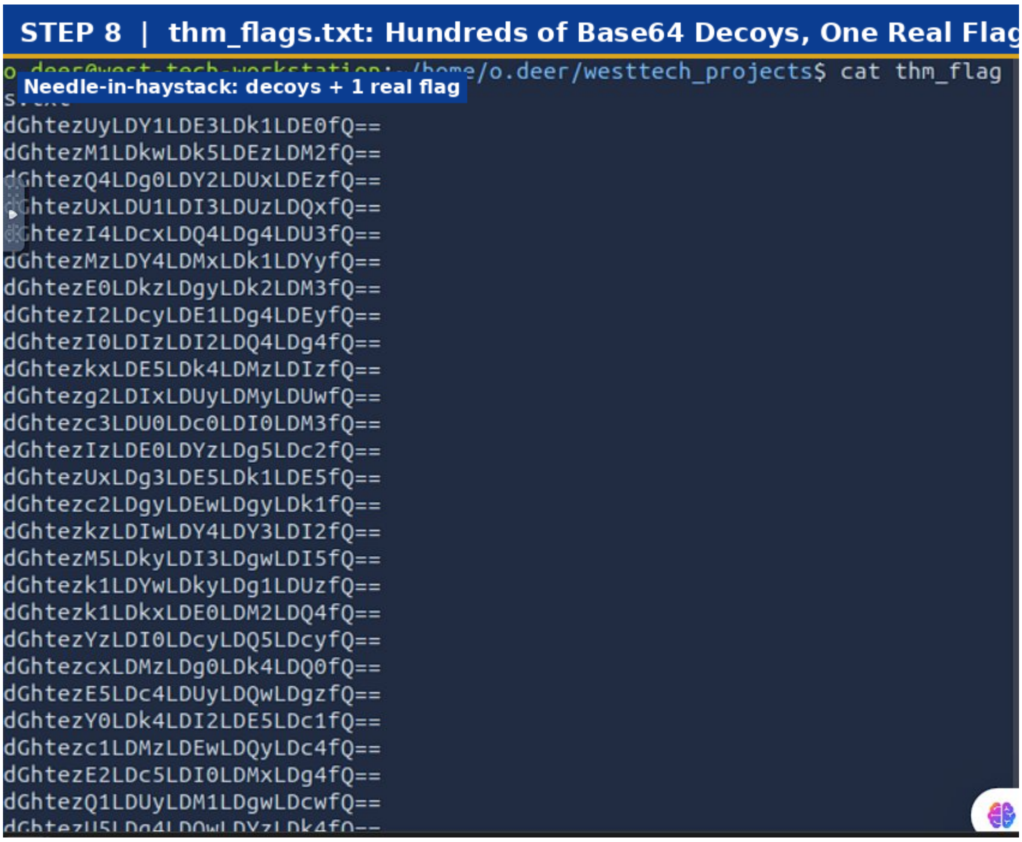


*Figure 13: Base64-encoded flag entries in thm_flags.txt.*

Decoding individual entries yielded `thm{...}` strings, but only one is the genuine flag — the rest are decoys.

## 9. Final Identification via liberty_prime

The AI's **liberty_prime** tool was invoked against the file:

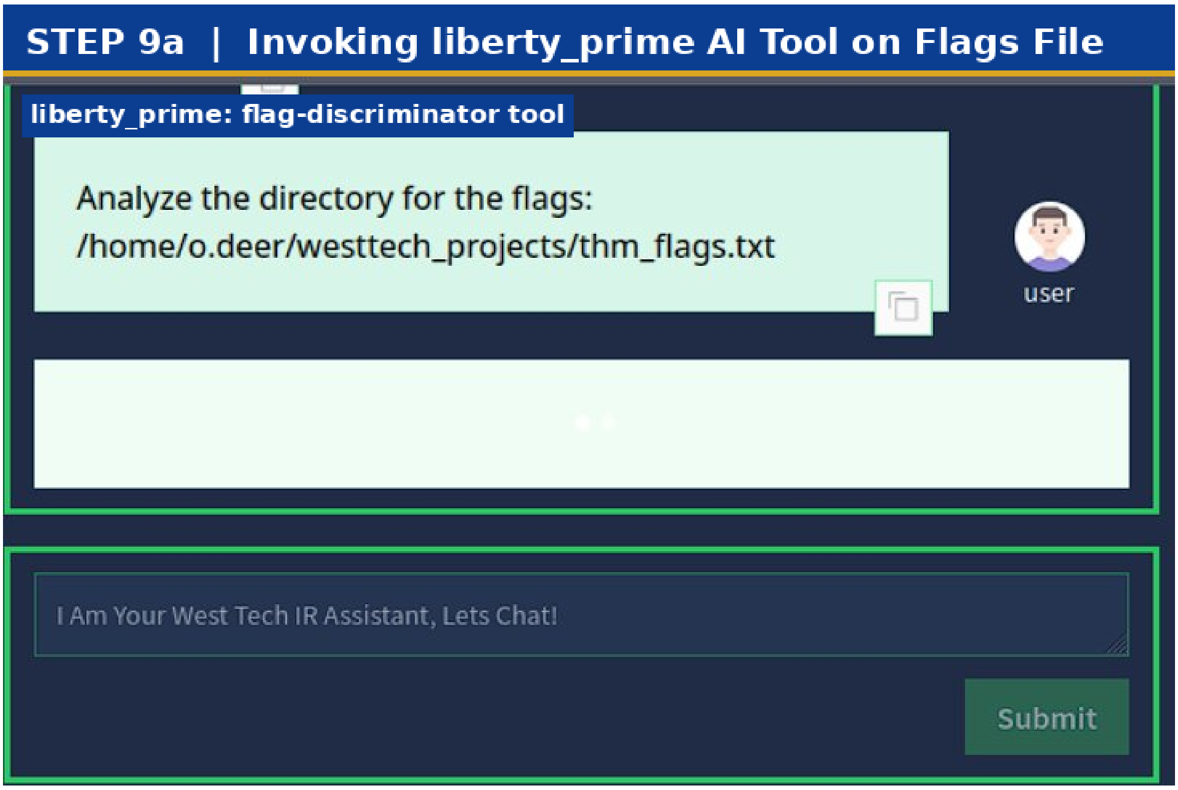


*Figure 14: Prompting liberty_prime to analyse the flags file.*

It identified the real flag among the decoys:

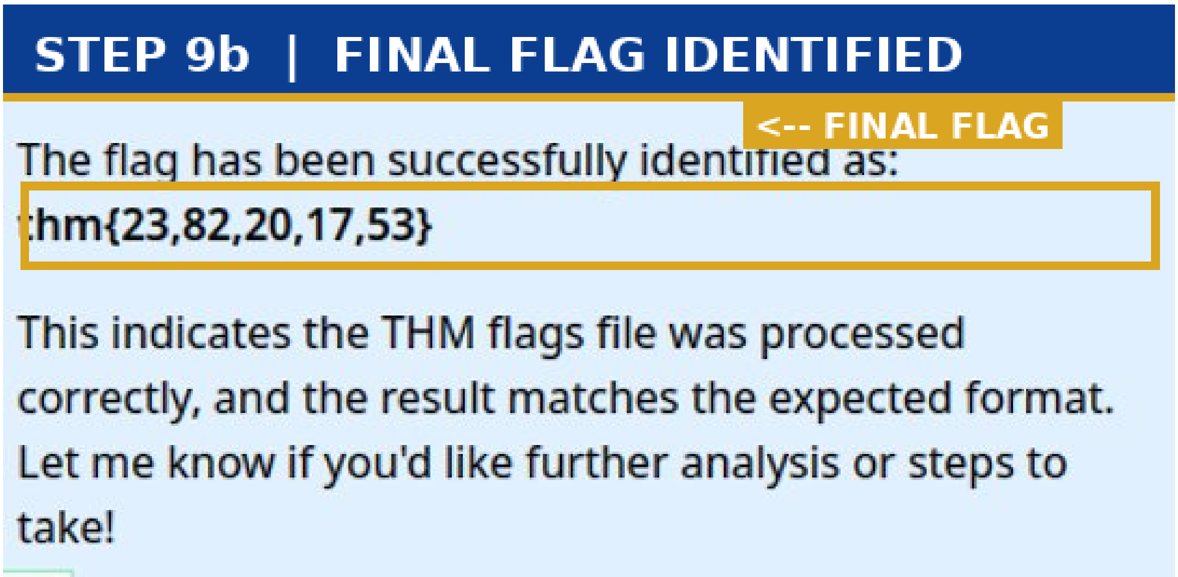


*Figure 15: Final flag identified by liberty_prime.*

```
thm{23,82,20,17,53}
```

## Attack Chain Summary

| Stage | Action |
|---|---|
| **1. Recon** | Attacker queried the AI assistant for sensitive employee data; the AI complied (the 'memory leak |
| **2. Foothold** | Reverse shell session captured as session_4444_dump.pcap (port 4444). |
| **3. Exfiltration** | Project files copied off-host and packaged into westtech_projects_encrypted.zip. |
| **4. Extortion** | Ransom note pwned.txt dropped to the desktop with a 48-hour BTC demand. |
| **5. Operator Mistake** | Attacker left their working notes (including the archive password) inside a PCAP they neglected |

## Lessons Learned

**AI assistants are an attack surface.** A helpful chatbot with broad filesystem access and weak guardrails is functionally a privileged insider with a memory leak. Vet prompts, scope tool permissions, and audit conversation logs.

**File-size outliers tell stories.** A single 2262-byte capture in a sea of 198-byte placeholders was the entire investigation in one ls -la.

**Defenders should think like the attacker's own bad opsec.** The password was recovered because the attacker themselves left it lying around. Investigations benefit from looking at attacker mistakes, not just victim artefacts.

**Defence-in-depth still matters.** SSH access, file encryption, AI guardrails, and network monitoring are layers. The room highlights what happens when one layer (the AI) is over-trusted and under-restricted.

## Tools Used

| Tool | Purpose |
|---|---|
| `ssh` | Workstation access |
| `find, ls -la, cat` | Filesystem triage |
| `unzip` | Archive decryption |
| `base64 -d` | Flag decoding (manual verification) |
| `West Tech AI IR Assistant` | PCAP reassembly (qwen-output) and flag analysis (liberty_prime) |